

Analysis of Certificate Transparency Logs: phishing campaign against Telegram

Santeri Kokkonen
Elza Latifi
Fariha Tahseen Karim

Ensimag, Grenoble-INP, France

Abstract

Digital certificates are essential for ensuring secure communication over the internet. They establish trust by enabling encryption and authentication between clients and servers. However, misuse of certificates, such as issuing them for malicious domains, poses significant threats. Certificate Transparency (CT) provides a public logging mechanism to detect and mitigate such risks. This paper presents a detailed model that uses CT logs to identify suspicious domains. We implemented new features of automated DNS lookup and a screenshot feature to an existing CT log analysis tool. With the model we were able to capture a part of a phishing campaign against social media and instant messaging platform Telegram. We captured a total of 156 phishing domains over the course of a total 10 hours. These phishing domains were not found by other similar projects such as URLAbuse or PhishTank.

Index Terms

Certificate Transparency, Phishing Detection, Digital Certificates, Cybersecurity.

I. INTRODUCTION

Clicking on a seemingly harmless link or advertisement can often redirect users to a malicious website. Phishing attackers exploit this vulnerability by imitating trusted entities to deceive individuals and organizations into revealing sensitive information, such as login credentials or financial details. These attacks remain a significant threat in the cybersecurity landscape. The malicious actors exploit the trust established by SSL/TLS certificates, which are intended to provide security and authenticity for online communication. Certificate Transparency (CT) is an initiative led by Google, addresses this challenge by creating a publicly auditable log of all certificates issued by Certificate Authorities (CAs). [1]

Despite the benefits of CT, the vast number of certificates issued daily makes manual monitoring infeasible. This project, conducted as part of our Master's-level cybersecurity course, aims to develop a real-time detection system for phishing websites using Certificate Transparency (CT) logs. Leveraging the CertStream API [2], we implemented heuristic-based methods to identify suspicious domains that may impersonate legitimate entities such as banks, e-commerce platforms, and postal services. During our analysis of Certificate Transparency (CT) logs using tools like URLAbuse [3], we observed a significant amount of phishing attacks targeting the social media and instant messaging platform Telegram. Notably, recent reports indicate that crypto phishing scams on Telegram have surged by over 2,000% since November 2024, driven by sophisticated malware-driven tactics [4].

The core problem this project addresses is how to effectively distinguish phishing websites from legitimate ones in real-time. Phishing websites often use legitimate certificates to appear authentic, making it challenging to detect them based solely on certificate data. By analyzing patterns in domain names, top-level domains (TLDs), and DNS resolutions, this project demonstrates an efficient method to identify and categorize suspicious websites. Our approach combines domain scoring, DNS verification, and visual inspection to provide an automated solution for phishing domain detection. Specifically, we evaluate domains using heuristic-based scoring criteria, including the presence of suspicious keywords, unusual top-level domains (TLDs), and entropy measurements to detect randomly generated or typosquatted domains. Flagged domains are further analyzed using DNS resolution tools like ZDNS to verify their existence by checking for active IP addresses or NXDOMAIN results. Finally, we employ automated tools such as Selenium to capture and analyze screenshots of resolved domains, enabling visual identification of phishing websites, such as fake login pages or impersonations of trusted platforms.

The rest of the paper is divided as follows: Section II presents the background information about certificate transparency. In Section III the methodology of the project is presented. In Section IV different tools, used in the project, are presented. In Section V the identified phishing campaign against Telegram is presented and discussed. Finally, conclusions are drawn in Section VI.

II. BACKGROUND INFORMATION

This section presents the background information of this paper

A. Digital certificates

Digital certificates issued by Certificate Authorities (CAs) enable secure communication by encrypting data transmitted between clients and servers. However, attackers often exploit the trust established by these certificates to deceive users. For example, malicious actors can request certificates for domains resembling legitimate ones, such as banking websites, to launch phishing attacks.

SSL/TLS certificates are critical for securing online communication by encrypting data exchanged between users and websites. However, the misuse of certificates, such as issuing them for fraudulent domains, poses a serious threat. Certificate Transparency (CT) addresses this issue by providing a public record of all certificates issued by Certificate Authorities (CAs). This system enables security teams and researchers to monitor and audit certificate issuance, enhancing transparency and trustworthiness in internet security.

Phishing websites, which mimic trusted brands to deceive users into providing sensitive information, often exploit SSL/TLS certificates to appear legitimate. These certificates—intended to secure online transactions—are sometimes issued for malicious domains, enabling attackers to execute phishing campaigns effectively. By analyzing CT logs in real-time, it is possible to identify such suspicious domains before they can be used maliciously.

Certificate Transparency, in essence, acts as a real-time ledger of internet security, and tools like CertStream open windows into this ledger. By leveraging such tools, this project offers a practical and scalable method to combat the ever-evolving threat of phishing.

III. LITERATURE REVIEW

As scammers grow increasingly smarter, their techniques continue to evolve. This stands as a daunting threat to online security. Our project aims to utilize Certificate Transparency (CT) logs to identify suspicious websites, addressing the ever-present need for advanced phishing detection methods.

This concept is not anything new; similar research efforts have been conducted over the years. One significant contribution to this field is the study titled "Catching Phishers By Their Bait: Investigating the Dutch Phishing Landscape through Phishing Kit Detection" [5], which focuses on the detection of phishing threats through the analysis of phishing kits. This research emphasizes how much data-driven approaches to uncover malicious patterns are pivotal [5]. The study relies on analyzing TLS certificates and kit fingerprints to identify phishing domains targeting the Dutch financial sector (September 2020 - January 2021) [5]. They collected 70 Dutch phishing kits from underground markets and categorized them into 10 distinct kit families and developed unique fingerprints for these kits to measure their deployment in phishing domains [5]. Lastly, they tracked the life cycle of 1,363 phishing domains, from registration to take-down. Automation is another important aspect discussed in the study where phishing kits incorporate automated tools to fingerprint these kits effectively, streamlining the identification process [5].

There have been investigations to observe the use of Certificate Transparency (CT) logs as a data source for reconnaissance in counterattacks which the research, "Certifiably Vulnerable: Using Certificate Transparency Logs for Target Reconnaissance" covered flawlessly [6]. This research highlights how CT logs can reveal patterns in certificate issuance and renewal, providing valuable insights into potential weaknesses in web security infrastructure [6]. What they did was, they deployed honeypots over 200 days to analyze traffic changes after adding certificates to CT logs. Then there were active scans to identify vulnerable websites using CT logs, focusing on newly deployed and expired certificate domains. It was found out that adding certificates to CT logs triggers immediate scanning, especially in IPv6 and expired certificate domains are more likely to run outdated software with known vulnerabilities (CVEs) [6]. Our thesis similarly incorporates real-time monitoring of CT logs, utilizing CertStream, ZDNS, and Selenium to streamline the phishing detection process. Both the studies mentioned provide a foundation for understanding how CT logs can be used to deal with cyber-security threats, which have plagued the digital ecosystem for decades [6].

IV. METHODOLOGY

A. Overview

In this project we started with an existing model called `phishing_catcher`. The model is a heuristics based, and it uses the CertStream API as the source of the CT log data. The model uses modifiable keyword list, where every entry is given some score. The model then tries to find these keywords or substrings similar to these in the domains. A general phishing keyword list is given with the model. The model also uses a wide range of other methods to determine level of suspiciousness of the domains.

This project builds upon the original model by adding two new features: automated DNS lookup and screenshot feature. These features were added to further analyze suspicious domains. Also, we modified the original keyword list. The analysis pipeline of our model is structured into the following steps:

- **Data Collection:** Real-time CT log data was fetched using the CertStream API. The API streams information about newly issued certificates, allowing immediate analysis of associated domains.
- **Keyword Analysis:** For general phishing domain approach we used the original keyword list, which covered different brands, generally suspicious keywords and TLDs, and others. Some of the keywords and their scores given in the following list:
 - **Generic:**
 - * login': 25
 - * 'log-in': 25
 - * 'sign-in': 25
 - * 'signin': 25
 - * 'account': 25
 - * 'verification': 25
 - * 'verify': 25
 - **Brands:**
 - * 'appleid': 70
 - * 'icloud': 60
 - * 'iforgot': 60
 - * 'moneygram': 60
 - * 'westernunion': 60
 - * 'bankofamerica': 60
 - * 'wellsfargo': 60
 - **TLDs:**
 - * '.ga'
 - * '.click'
 - * '.icu'
 - * '.vip'
 - * '.dev'
 - * '.xyz'

However, for a more targeted approach the keyword list can be modified to include only relevant keywords.

- **DNS Resolution:** Using ZDNS, flagged domains were resolved to determine if they pointed to active IP addresses. NXDOMAIN results were not considered.
- **Screenshot Capture:** Selenium was utilized to automate browsers and capture visual evidence of resolved websites, focusing on identifying phishing-like content.
- **WHOIS Lookup:** Ownership and registration details were obtained using manual WHOIS queries, with anonymized or suspicious registrars noted for further investigation.

B. Scoring and Filtering

Domains were assessed based on the following criteria:

- **Presence of Suspicious Keywords:** Domains containing high-risk terms like "secure," "login," or "account" were assigned higher scores.
- **TLD Analysis:** Free or unusual TLDs (e.g., ".xyz", ".tk") were penalized.
- **Domain Structure:** Excessive subdomains, hyphens, or other irregular structures were flagged and penalized.
- **Shannon Entropy:** Domains with high entropy values, indicative of random or typosquatted names, were scored higher for suspicion.

Domains exceeding a predefined threshold were flagged for further scrutiny, which included DNS resolution and screenshot capture.

C. DNS Resolution and Screenshot Capture

For flagged domains:

- **DNS Resolution:** ZDNS resolved domains to verify their existence and connectivity. Domains returning NXDOMAIN results were not considered.
- **Screenshot Capture:** Selenium captured screenshots of active domains to visually inspect phishing characteristics, such as fake login pages or impersonations of trusted entities like Telegram.

D. WHOIS Lookup

Using WHOIS queries, the project gathered domain ownership and registration details. This step provided additional context for evaluating flagged domains.

E. Workflow Summary

The project’s methodology operates as a sequential pipeline: **Data Collection** → **Keyword Analysis** → **Scoring and Filtering** → **DNS Resolution** → **Screenshot Capture** → **WHOIS Analysis**. This multi-layered approach ensures a comprehensive and robust detection system capable of identifying and mitigating phishing threats in real-time.

V. TOOLS AND DATASETS

A. Tools

The tools utilized in this study were selected to address various aspects of real-time phishing detection and analysis. These include:

- **CertStream API**: Enables real-time access to Certificate Transparency (CT) logs, providing a continuous feed of newly issued certificates for analysis.
- **ZDNS**: A high-performance DNS resolution tool used to verify if flagged domains resolve to active IP addresses or return NXDOMAIN results.
- **Selenium**: A browser automation tool employed for capturing screenshots of flagged domains, allowing visual inspection of phishing content.
- **URLAbuse**: A resource for identifying and reporting malicious URLs, utilized to cross-reference flagged domains with known phishing datasets. [3]
- **OpenPhish**: A phishing feed service that validates flagged domains by comparing them against a continuously updated database of known phishing sites. [7]
- **WHOIS Services**: Tools such as `whois.com` were used to retrieve domain registration and ownership details, aiding in the identification of suspicious registrars or anonymized ownership.
- **Certificate Transparency Repository**: As previously mentioned the phishing_catcher GitHub Repository https://github.com/x0rz/phishing_catcher provided foundational resources and tools for Certificate Transparency analysis, which were extended and customized for this project.

B. Similar projects

Other similar projects were used to cross-reference captured results and to analyze potential phishing campaigns. These include:

- **OpenPhish Feeds**: Provided a trusted dataset for validating flagged domains against known phishing websites.
- **URLAbuse Blacklist**: A community-driven blacklist used to cross-reference flagged domains, ensuring accurate identification of malicious URLs.
- **PhishTank**: PhishTank is a collaborative clearing house for data and information about phishing on the Internet.
- **Google Safe Browsing**: Safe Browsing is a service that Google’s security team built to identify unsafe websites across the web and notify users and website owners of potential harm.

These tools supported a comprehensive pipeline for detecting and analyzing phishing websites, from initial identification to detailed verification.

VI. PHISHING CAMPAIGN AGAINST TELEGRAM JANUARY ON 2025

This chapter goes over how we identified a phishing campaign against Telegram, how we captured a part of it, and our analysis on it.

A. Motivation

Our initial approach was to detect a wider array of Phishing URLs. However, with this approach majority of the URLs we flagged did not have valid IP addresses behind them, and thus we could not take screenshots. Hence, we researched the URLAbuse phishing feeds and identified that on multiple days one of the most targeted brand was the social media and instant messaging platform Telegram.

Looking at the screenshots uploaded on URLAbuse and also visiting the phishing URLs we saw that they imitating Telegram login pages. One of the screenshots of a reported Telegram phishing website found on URLAbuse pictured in figure 1.

Due to the large amount of already found phishing websites imitating Telegram on URLAbuse, and Telegram being in the top 3 most phished brands on OpenPhish during the time of this study, we decided to focus on only trying to find Telegram phishing URLs.

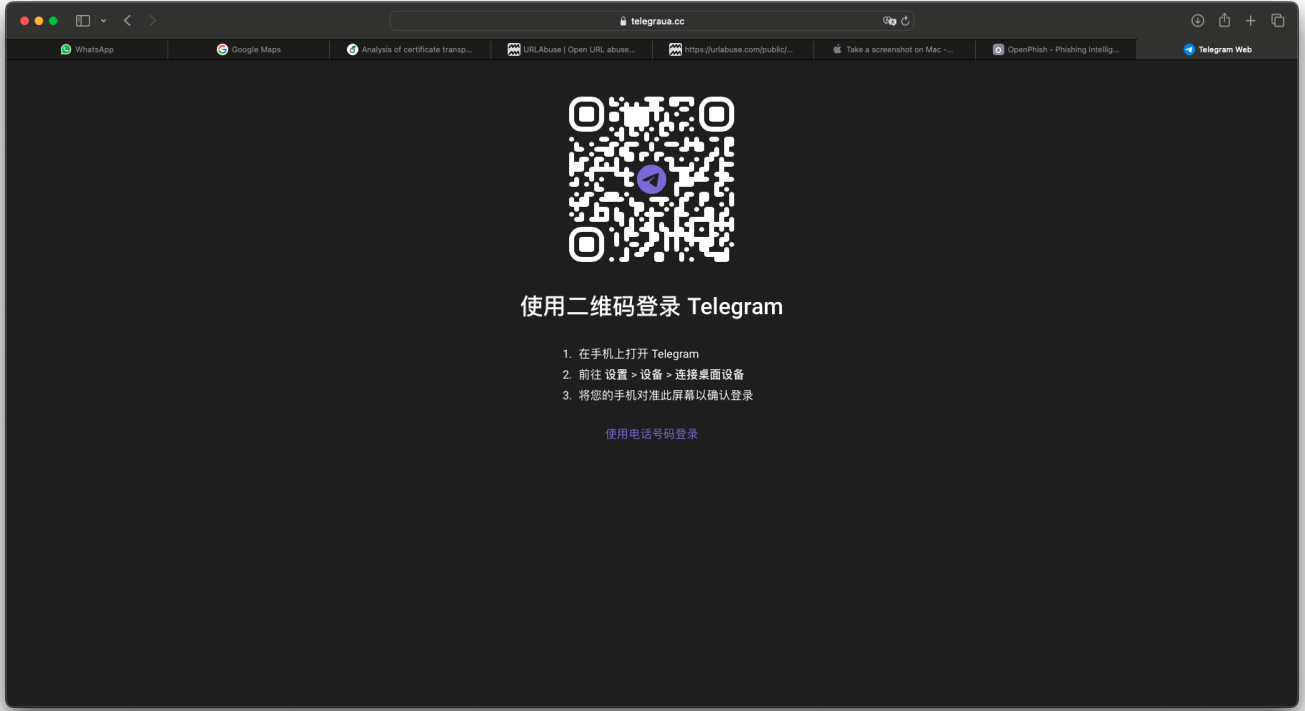


Fig. 1. Screenshot of a Telegram phishing website

B. Tool modifications

In order to focus solely on telegram, we only used telegram related keywords in the URL scoring. In addition to "Telegram", we added multiple different URLs that resembled the brand name such as: "telenerh" or "tl-legrum". We had noticed these types of URLs when researching URLAbuse. Additionally, we changed to binary classification of phishing or not phishing domain names.

After the modifications the classification was conducted as follows:

- Consider only domain names under 20 characters. We noticed that the phishing URLs on URLAbuse tried to accurately imitate the real Telegram URL and thus were short.
- If domain name contains "Telegraph" do not consider it. Without this change our program flagged many Telegraph related URLs.
- If the domain contains any of the keywords, flag it.
- Split the domain name over the characters '.' and '-'. In both cases, check whether any of the resulting strings are a Levenshtein distance of 1 from any of the keywords over the length of 7. If yes, flag the URL. This step ensures that most one letter changes to the keywords are noted. The length requirement of 7 was implemented to avoid false positives with shorter words.

Additionally, when we analyzed the Telegram phishing URLs on URLAbuse, we found that, in addition to URLs with no paths, many URLs were using the paths "/login", "/app", "/en". Thus, with every flagged domain name we took a total of 4 screenshots: no path, "/login", "/en", "/app". The block diagram of a single iteration of the program is depicted in figure 2

C. Results

We ran the program a combined time of nearly 10 hours. The results of these runs are presented in table I, where #Flagged&SS was the number of flagged domains that had an IP address behind it and it was possible to take a screenshot of the page. The times presented in the table are not exact. The confirmation of the flagged domains were done visually. If a screenshot of the domain resembled a Telegram login page it was counted as a confirmed phishing domain. However, the number of confirmed phishing domains is not totally accurate, because many of the flagged domains had blank web pages at the time of the screenshot, but on later inspection there was a phishing page. We suspect that on the 2nd run of the program there is

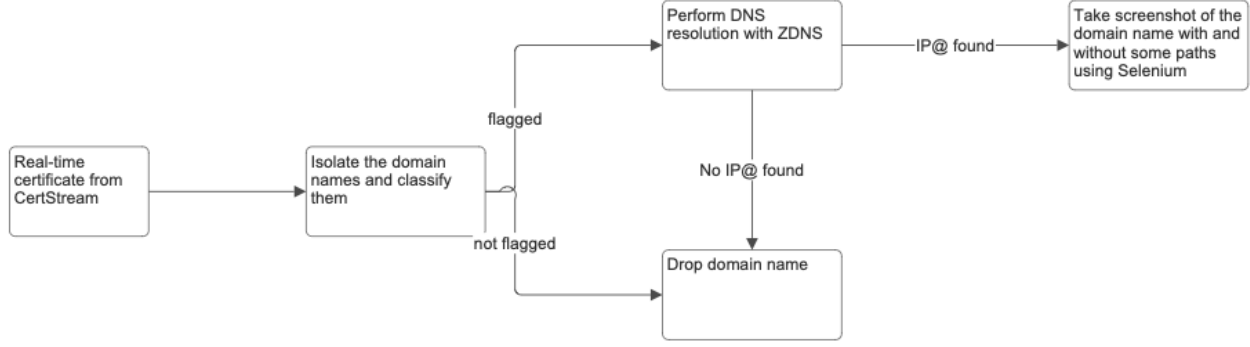


Fig. 2. Block diagram of a single iteration

TABLE I
RESULTS

Time	#Domains	#Flagged	#Flagged&SS	#Confirmed	$\frac{\text{\#Confirmed}}{\text{\#Flagged\&SS}}$
20th January 2025, 13.30-17.30	2046776	686	116	75	$\frac{75}{116} \approx 0.65$
20-21th January 2025, 22.00-07.45	4055939	1268	251	81	$\frac{81}{251} \approx 0.32$
Total	6102715	1954	367	156	$\frac{156}{367} \approx 0.43$

approximately 50 of these. In these cases, also, the domain names seem to follow the same pattern as with confirmed ones. Also noteworthy, some domain names appeared on the CT log multiple times, and thus also got flagged multiple times.

Observations of the results:

- All of the successful screenshots were taken from URLs with no path. None of the phishing domains did not have anything behind the paths: `"/login"`, `"/app"`, `"/en"`.
- All of the successful screenshots, with a dozen or so exceptions, captured the same phishing web site pictured in 3.
- All of the domains manually inspected afterwards resolved to http connections, and thus they did not have certificates.
- Majority of the domains seemed to have same pattern in their second level domain: 7 or 8 character length, starts with `"teleg"` or `"tele"` and ends in some random string or word of length 3 or 4 usually starting with `'r'`.
- The confirmed phishing domains are also flagged on Google Safe Browsing as unsafe, but not on URLAbuse or Phishtank
- The confirmed phishing domains used a wide range of unusual TLDs such as: `".baby"`, `".skin"`, `".asia"`, `".rent"`, `".boats"`, `".cyou"` etc.. Many of these TLDs were significantly cheaper than more common ones like `".com"`.
- Manually checking with WHOIS some of the confirmed domains revealed that they were always registered the same day and were using Dynadot as their registrar.

D. Discussion

We were surprised by the amount phishing domains we were able to capture. The findings confirmed that Telegram was a big target for Phishing. We are also content that our program achieved a 43% success rate among the flagged domains. More, if we were to take into account also the domains that later had phishing web sites behind them, we suspect that the success rate would be around 60%. Additionally, many of these observations point to the result that there is some single entity or actor who is behind the captured phishing websites and that we captured a part of a larger phishing campaign against Telegram.

However, our results did not appear on other similar projects, such as URLAbuse, or vice versa. We were unable to find out why our results differed or which sources does URLAbuse uses. Additionally, we find it unusual that when later accessing the domains, none of them had certificates.

More, we suspect that with better keyword heuristics or some type of machine learning model we would be able to capture even more phishing domains. Also, making our program run in parallel would allow us to analyze more of the CT logs. We suspect that, with our current program, during the time that it takes to take a screenshot, we do not analyze the certificates given.

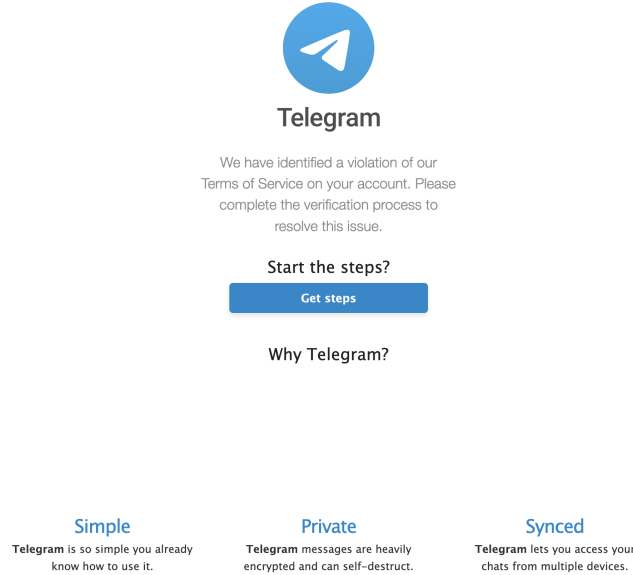


Fig. 3. Captured Telegram phishing web site

VII. CONCLUSIONS

In this paper, we presented a heuristics based model inspired by the Github repository phishing_catcher. We further improved the model by automating a DNS lookup using zdns and by adding a screenshot feature.

The goal of this paper was to research how to detect phishing from CT logs. Although we started with a general approach, we identified and then focused on a phishing campaign against the social media and instant messaging platform Telegram.

We were able to capture and confirm a total of 156 Telegram phishing domains over the course of almost 10 hours. Although, we have reason to believe that with further inspection the number of captured and confirmed domains would be around 220. Also, we suspect that all of the, with a few exceptions, captured domains belong to the same campaign and is orchestrated by the same entity. Our results were novel in that sense that the domains that we captured were not flagged on other similar projects as URLAbuse or PhishTank.

However, we recognize multiple different avenues for future work. Firstly, processes in our model could be automated such as screenshot or WHOIS analysis. Secondly, a machine learning approach should also be researched, or more extensive keyword list should be utilized. More, further data analysis on the results should be done.

We have published the model and our result data on Github [8].

ACKNOWLEDGMENT

We thank our cybersecurity teachers for their guidance and support throughout this project.

REFERENCES

- [1] Google certificate transparency. Accessed: 2025-01-01. [Online]. Available: <https://certificate.transparency.dev>
- [2] Certstream api. Accessed: 2025-01-01. [Online]. Available: <https://certstream.calidog.io>
- [3] Urlabuse. Accessed: 2025-01-22. [Online]. Available: <https://urlabuse.com>
- [4] Crypto scams grow on telegram as threats surge by 2000%. Accessed: 2025-01-13. [Online]. Available: <https://beincrypto.com/telegram-crypto-scams-grow/>
- [5] Unknown, "Certifiably vulnerable: Using certificate transparency logs for target reconnaissance," *IEEE Xplore*, 2025, accessed: 2025-01-23. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/10190522>
- [6] —, "Catching phishers by their bait: Investigating the dutch phishing landscape through phishing kit detection," *USENIX Security Symposium*, 2021, accessed: 2025-01-23. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity21/presentation/bijmans>
- [7] Openphish. Accessed: 2025-01-22. [Online]. Available: <https://openphish.com>
- [8] Project github repository. Accessed: 2025-01-23. [Online]. Available: <https://github.com/Santtu-K/Certificate-transparency>